Triage de alertas SOC sobre 2M de eventos (Precinct6)

Propuesta de proyecto — Aprendizaje Automático

Author Name

8va sesión · 15 min + 5 min preguntas

1. Problema: ¿qué abordamos?

Triage de alertas SOC: dado un evento de seguridad, predecir su tier (`benign` / `suspicious` / `malicious`) con probabilidades, hints MITRE ATT&CK y decisión operativa (`escalar` vs `monitorear`).

- Entrada: 1 evento (campos + mensaje crudo + vecindario ± 5 min).
- Salida: (y, p) + técnicas + triage, en < 50 ms para rankear la cola.

1. Motivación: ¿por qué importa?

- **Volumen**: 2,011,674 eventos en 6 días, 4 orgs, 19 productos — imposible a mano.
- **Desbalance extremo**: solo 0.38 % malicious (IR 245:1); el accuracy miente (94 % con siempre-benign).
- **Contexto**: decidir exige mensaje + MITRE + cadena, no solo un score (disposition = `Unprocessed` en 2,005,877/2,011,674).
- Ground truth = correlación automática de Precinct: oráculo fuerte pero imperfecto.

2. Literatura (1/3): panorama

- **Provenance-graph IDS**: NODLINK (NDSS 24, APT online), KnowHow (NDSS 26, interpretable), FLASH (S&P 24, GNN temporal), threaTrace/GraphSAGE (base de M3).
- **CTI + LLM**: OMNISEC (RAG), PROVSYN (síntesis contra desbalance), TRAM MITRE (mapeo a ATT&CK + notebooks).
- **Imbalance/texto**: Focal Loss, cost-sensitive IDS (FN>>FP), TF-IDF gana a BERT con poco dato (P 75 %, F1 64 %).
- Simuladores: CybORG (despliegue como agente SOC).

2. Literatura (2/3): Caso Devign

Devign (Zhou et al., NeurIPS 2019): GNN sobre grafos de código, binaria a nivel función.

- Datos manuales ∼600 h-persona, 4 libs C (Linux, QEMU, Wireshark, FFmpeg).
- **+10.51 % accuracy / +8.68 % F1** vs baselines; +27.99 % F1 vs analizadores; 74.11 % en 40 CVEs nuevos.
- Lección para nosotros: **precedente GNN de M3** — grafos + aprendizaje > reglas. Contraste: ellos etiquetas caras/limpias, nosotros Precinct baratas/ruidosas.

2. Literatura (3/3): Caso CVSS-BERT + tabla

CVSS-BERT (Shahid & Debar, IEEE ICMLA 2021): 8 BERTs (uno por métrica CVSS) desde la descripción del CVE (45,926 CVEs); severidad MAE 0.73, 55.3 % match exacto, con saliency explicable. Límite: el CVSS varía según quién asigna.

	Devign	CVSS-BERT	Nosotros
Input	grafo código	texto CVE	tabular + texto + subgrafo
Etiquetas	manuales 600 h	NVD experto	Precinct auto
Modelo	GGNN+Conv	8 × BERT	LightGBM / TF-IDF+XGB / vecindario+XGB
Lección	grafos > estáticos	texto→severidad + explicar	cascada M1→M2→M3 + explicar

3. Solución y proceso

`signals` → prepro P1–P5 → M1 rankea / M2 confirma texto / M3 confirma cadena → fusión → consola.

End-to-end pipeline



Prepro: one-hot sanitizado, temporales + split temporal 80/20 (anti-leakage), anti-desbalance sin SMOTE, TF-IDF 5k, subgrafo ± 5 min. Modelos + complejidad en el paper.

3. Modelos (qué mide cada uno)

	M1 tabular	M2 texto	M3 grafo
F1-macro	0.599	0.708	**0.719**
Recall malicious	0.004	0.970	0.962
PR-AUC$_{mal}$	0.30	0.83	0.82
Latencia	$<$50 ms	$\sim$100 ms	$\sim$s

M1 recupera suspicious (R 0.96) pero pierde malicious; M2/M3 cazan malicious a costa de suspicious. Extra: M4 multi-label ATT&CK (micro 0.75/macro 0.25) $\rightarrow$ capa honesta tier$\rightarrow$técnicas en `/score`.

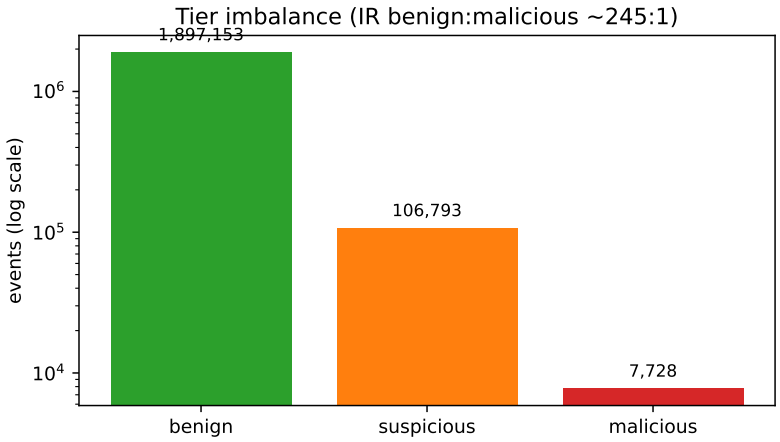
4. Dataset

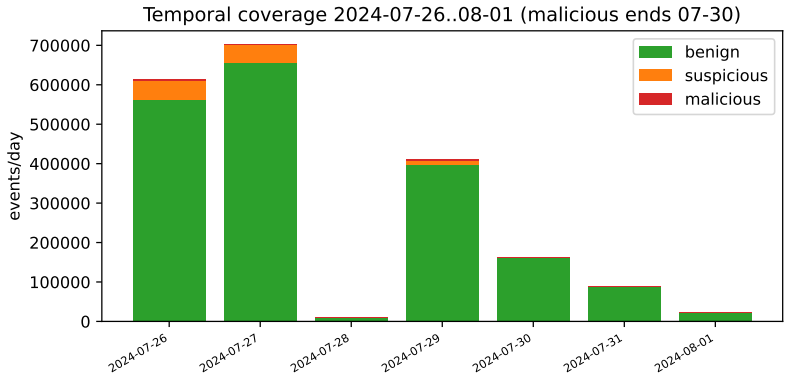
`witfoo/precinct6-cybersecurity` v2.1.0 (Apache-2.0): captura live 2024-07-26 $\rightarrow$ 08-01.

Tier	Filas	%
benign	1,897,153	94.31
suspicious	106,793	5.31
malicious (1,584 incidentes)	7,728	0.38
Nodos / aristas / incidentes+reporte	47,585 / 1,740,438 / 51,371	
Reglas / productos / vendors	261 / 19 / 12 observados	

38 columnas por señal + `incident_signals` histórico (238k) + GraphML por incidente.

4. Visualización





IR 245:1 (log) y cobertura temporal: malicious termina 07-30, benign sigue a 08-01 $\rightarrow$ split temporal, no shuffle. EDA completo reproducible: `src/eda_report.py` $\rightarrow$ `reports/eda/` (diccionario, missingness, leakage, drift, hipótesis).

Demo y cierre

Demo (20 min, `docker compose up` → :8000): Cola → puntuar (ATT&CK) → vecindario M3 → Incidente (cadena+reporte) → Cobertura MITRE.

- Contribución: pipeline reproducible + 3 prepros + 3 modelos con complejidad + consola desplegada.
- Límite honesto: labels Precinct $\neq$ verdad analista; T1190+ORG-0004 dominan; M4b no desplegado (P 0.08).
- Siguiente: ATT&CK multi-label con SciBERT (notebooks TRAM) + aumento TTPXHunter para la cola.

Gracias — preguntas (5 min).

Referencias

Devign, NeurIPS 2019 (arXiv:1909.03496) ▪ CVSS-BERT, ICMLA 2021 (arXiv:2111.08510) ▪ NODLINK NDSS 24 (2311.02331) ▪ KnowHow NDSS 26 (2509.05698) ▪ FLASH S&P 24 ▪ PROVSYN (2506.06226) ▪ OMNISEC (2503.03108) ▪ Survey (2006.01722) ▪ threaTrace (2111.04333) ▪ GraphSAGE (1706.02216) ▪ CybORG (2002.10667) ▪ Focal Loss (1708.02002) ▪ TF-IDF-vs-transformers (2407.06753) ▪ Two-stage LLM (2411.18755) ▪ TRAM (MITRE CTID) ▪ ATT&CK `https://attack.mitre.org/` ▪ Dataset `https://huggingface.co/datasets/witfoo/precinct6-cybersecurity`